



ABDM Sandbox Exit Process WASA/Security Testing/VAPT

ABDM – Largest Healthcare Initiative



- The **Ayushman Bharat Digital Mission (ABDM)** is a groundbreaking national health initiative launched by the Government of India in 2021.
- The mission aims to create a comprehensive and interconnected digital health ecosystem that will revolutionize healthcare delivery across the country.
- By leveraging technology, ABDM aims to address the challenges of fragmented healthcare data, limited access to quality care, and the need for improved coordination among healthcare providers.
- Suma Soft is one of the certifiers appointed by National Health Authority (NHA) for ensuring compliance to ABDM guidelines by ecosystem players.

**Securing
Applications and
API endpoints
within the ABDM
Ecosystem and
Providing
Certifications
based on NHA
Guidelines**

Leading ABDM Security Certifier in India



Snapshot of Healthcare Domain companies and modules tested so far

Application Modules Tested	Count
Hospital Management System (HMS)	40+
Billing software	50+
Outpatient Department (OPD)	40
Indoor Patients Department (IPD)	33
Patient registration	200
Radiology	47
Pathology	57
Pharmacy	15+

Type of Organizations worked with	Count
Insurance Companies	20
Telemedical Applications	33
Health Tech Service Providers	20
Technical Service Providers	11
Personal Health Record Providers	02

Service Offered Apart From WASA

Our Cybersecurity Services Portfolio



Assessment

- ❖ Information Security Assessment
- ❖ Vulnerability Assessment / Penetration Testing
- ❖ Digital Risk / Dark Web Assessment
- ❖ Red Team Assessment
- ❖ Web & Mobile Application Security Assessment
- ❖ Thick Client / Desktop Application Security Assessment
- ❖ API Security Assessment
- ❖ Security Code Analysis



Cloud Security

- ❖ Cloud Infrastructure Security Assessment
- ❖ Cloud Security Monitoring
- ❖ Cloud Security Posture Management
- ❖ Multi-Cloud Managed Security Services



Managed Security

- ❖ 24*7 Security Monitoring / SOC Services
- ❖ Managed Endpoint Detection & Response
- ❖ Patch Management as a Service
- ❖ Vulnerability Advisory Service
- ❖ Virtual CISO Service
- ❖ Deployment of various Security Technologies

Service Offered Apart From WASA

Our Cybersecurity Services Portfolio



IT Governance, Risk & Compliance

- ❖ Enterprise-wide IT / Information Security Audit
- ❖ Formulation of IT Policies, Procedures and Guidelines
- ❖ Data Privacy Assessment and Controls Implementation
- ❖ API Governance and Security Audit
- ❖ Cyber Audits based on Regulatory Guidelines (RBI / SEBI/ IRDA)
- ❖ ISO 27001, SOC 2 & HIPAA Implementation Assistance
- ❖ Compliance to Regulatory Guidelines and Security Best Practices
- ❖ Third Party (Vendor) Information Security Assessments



Digital Forensics

- ❖ Digital Forensics Investigations
- ❖ Ransomware Readiness Assessment
- ❖ Employee Misconduct Investigations
- ❖ Incident Response Services including Preparedness Assessment
- ❖ Digital Forensics Readiness Assessment
- ❖ Secure Wipe-out as a Service



Enterprise Security Solutions Implementation

- ❖ Cyber Threat Intelligence
- ❖ Application Security
- ❖ Breach & Attack Simulation
- ❖ Cloud Security Posture and Vulnerability Management
- ❖ SIEM / Security Analytics, Network Detection & Response (NDR)
- ❖ OT & IoT Security
- ❖ Identity and Privileged Access Management (IAM / PAM)
- ❖ Secure Access, Passwordless Authentication, MFA, Trxn Security

ABDM Sandbox Exit Process

← → ↺ sandbox.abdm.gov.in/docs/integration_and_exit_process     


[Home](#)
[Documentation](#)
[FAQs](#)
[Our Partners](#)
[Dashboard](#)
[Guidelines ▶](#)
[Cowin](#)
[Resources ▶](#)
[Discussion Forum](#)
[Contact Us](#)
[Login](#)

▶ Building blocks

▶ Overview of FHR framework

▼ Implementer's guide

What is already available

What resources can I use

[ABDM Sandbox integration & exit process](#)

▶ Building HIP

Facility share profile

Building HIU

Building Health Locker

Building ABHA Mobile Application

▶ Building UHI Applications

Key concepts

Getting started with APIs

Step 1: Functional & non-functional Testing of the application by an internal NHA team Draft test cases for functional evaluation can be found in download link

Test cases for M1 [Download](#)

Test cases for M2 [Download](#)

Test cases for M3 [Download](#)

Note : From 5th August 2022 onwards, the functional & non-functional testing of the application will be conducted by NHA empaneled agencies which are as below:

- M/s FIME India Pvt. Ltd.
- M/s Suma Soft Pvt. Ltd.
- M/s Tata Communications

The interested integrators are requested to connect with any one of the above agencies for functional and non-functional testing/certification on chargeable basis. The integrators (new and the existing ones) who are not able to get themselves certified by the cut off date will be required to get the testing conducted by any of these agencies only. Please [click here](#) for contact details of the above agencies.

Step 2: Security testing of the web/mobile application from any STQC or CERT-IN empaneled agency. Applicants are requested to engage with relevant agencies and submit the "Safe-to-Host" certificate to NHA

- Suggestive pointers on infrastructural requirements for security testing clearance can be found in [document](#) .

Available Publicly On - https://sandbox.abdm.gov.in/docs/integration_and_exit_process



WASA Scope!

FAQ Available On <https://sandbox.abdm.gov.in/sandbox/v3/faq>

Is WASA required for entire application or specific module?



The WASA is required for the entire application or specific module as per the requirement. The WASA for entire application is required if no WASA has been conducted for the application before moving to the production. The WASA is required separately for all modules if modules are being developed sequentially. For example, for an application 'XYZ' (in production for which WASA certificate has already been issued) an additional module A has been added. The WASA only needs to be conducted for the sequential module A subtracting the application part 'XYZ'.

1. In accordance with the ABDM Guidelines, the entire application with some common modules/page HMIS/LMIS etc application should have must be Security Tested / WASA (VAPT) certified from any CERT-IN/STQC Empanelled Agency before the integration process with the ABDM ecosystem can start.

2. If the entire application has recently received security certification from a CERT-IN/STQC Empanelled Agency, the organisation/customers should only perform WASA on M1/M2/M3 APIs; **otherwise, the customer must perform WASA on the entire application plus ABDM APIs to make them self eligible for Sandbox exit.**



Scope For WASA

1. [Scope/Scenario 1] – If the entire application is not already certified from any CERT-IN/STQC Empanelled Agency

If your existing application in which you intent to integrate ABDM/PHR APIs are not Security Tested / WASA (VAPT) certified recently from any CERT-IN/ STQC Empanelled agency, then you will be required to get the same in place. Our Security team need separate application(s) walkthrough and based on the same, we will share our commercials and estimated timeline for conducting Security Testing / WASA (VAPT) Certification.

2. [Scope/Scenario 2] – If the entire applications is already certified from any CERT-IN/STQC Empanelled Agency

If your application(s) is already Security Tested/ WASA (VA/PT) certified recently from any CERT-IN/STQC Empanelled agency, then only relevant ABDM/PHR API (M1/M2/M3) Or P1,P2,P3 P4 integration module(s) and its associated parts are needed to complete WASA certification rather than the entire application

Timeline For Only Scope/Scenario 2

M1	1 Day For 1 st Round	1 Day Re-Testing (2 nd Round)
M2	2 Days For 1 st Round	1 Day Re-Testing (2 nd Round)
M3	2 Days For 1 st Round	1 Day Re-Testing (2 nd Round)

P1	2 Days For 1 st Round	1 Day Re-Testing (2 nd Round)
P2	2 Days For 1 st Round	1 Day Re-Testing (2 nd Round)
P3	2 Days For 1 st Round	1 Day Re-Testing (2 nd Round)
P4	2Days For 1 st Round	1 Day For 1 st Round



Proactive WASA Process (Recommended)

1.Non-ABDM/Non-PHR WASA = This refer to your Core Product ex. HMIS/LMIS/MobileApp Software which does not have any ABDM/PHR APIs integrated. **We call it Non-ABDM Part.**

2.ABDM/PHR API WASA = This refer the Screen where ABDM/PHR APIs are Integrated, On average there would be 1 to 5 screens which may have ABDM/PHR APIs feature, **We call these 1 to 5 screens ABDM/PHR Part**

Testing Process for ABDM APIs (M1/M2/M3) & Non-ABDM Part

1. Start WASA Testing on the Non-ABDM Part

- This happens **regardless of whether M1/M2/M3 APIs are developed or not.**

2. Check if M1/M2/M3 APIs are developed

- **No** → Customer continues developing M1/M2/M3 APIs while WASA Testing on the Non-ABDM Part continues.
- **Yes** → Proceed to **Functional Testing of M1/M2/M3 APIs.**

3. If Functional Testing of M1/M2/M3 APIs is successful

- Start **WASA Testing on M1/M2/M3 APIs.**

4. **Final Step** → Testing process is complete.



Steps to Mandatory Requisite For WASA By CERT-IN

Who is CERT-IN - The Indian Computer Emergency Response Team (CERT) is an office within the Ministry of Electronics and Information Technology of the Government of India. It is the nodal agency to deal with cyber security incidents. It strengthens security-related defence of the Indian Internet domain.

Cert-In has recently introduced changes to the **Comprehensive Cyber Security Audit Policy Guidelines** (available at [link](#)). These changes directly impact the eligibility of applications for security testing for all the entity who are going for ABDM SandBox Exit (WASA Testing)

As per the revised guidelines, before initiating any security assessment (WASA), the **auditee organization must confirm** that the application has been designed and developed in line with secure coding and development practices by filling a sheet Suma Soft has prepared based on CertIN Guidelines. Compliance with the **CERT-In Secure Application Guidelines** (available at [link](#)) is now a mandatory prerequisite to start WASA.



Steps to Mandatory Requisite For WASA By CERT-IN

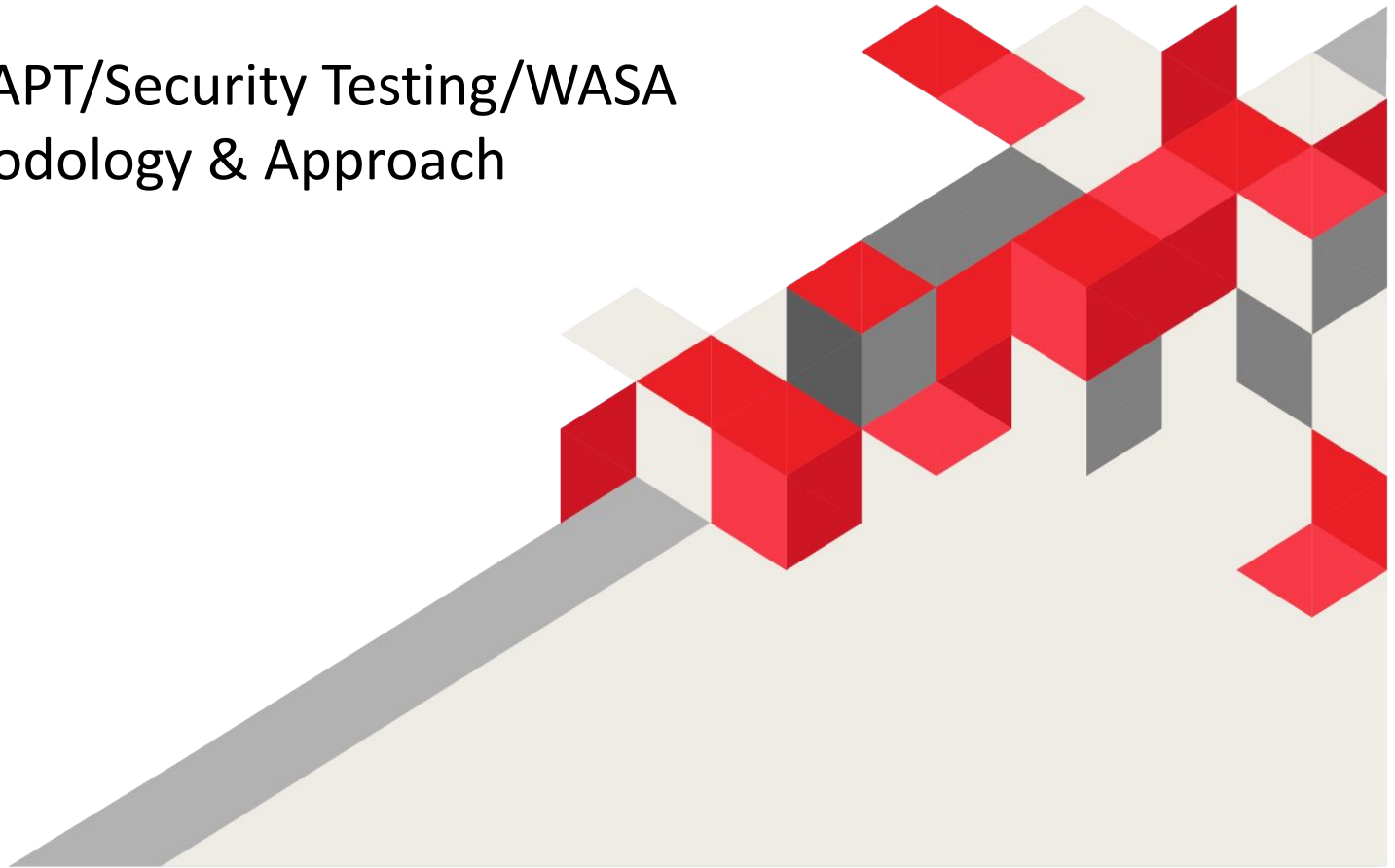
To comply, we will request entities to

1) Review the attached checklist (Excel) and confirm adherence to secure development practices

2) If they are found eligible, Customer will set up a call with Suma Soft Tema and over the call only Suma Soft will validate your excel sheet inputs. If they are found valid then only after Suma Soft can we initiate the proposal and proceed with the security testing (WASA)



Suma Soft VAPT/Security Testing/WASA Methodology & Approach



Suma Soft Pvt. Ltd.

Mandatory Pre-Requisite For WASA By CERT-IN

Applications not aligned with secure design and development principles will not be eligible for security testing or audit. Reference available (available at [link](#) Page No 23 at point no viii) In such cases, the auditee organization will be formally notified, and a copy of the communication will also be shared with Cert-In

[in.org.in/PDF/Application_Security_Guidelines.pdf](https://www.certin.org.in/PDF/Application_Security_Guidelines.pdf)).

- vi . Application developed without any secure design and development practices should not be considered for assessment and audits. The same

Version 1.0 | 25.07.2025

Page 23

should be informed to the auditee organization in writing with a copy marked to CERT-In. Auditee organizations and auditor organizations must confirm that application is designed & developed with secure practice prior to commencing any assessment.



Methodology

- Use of Open Web Application Security Project (OWASP) as testing
- Highlight the vulnerabilities as per OWASP Web, Mobile Top Ten criteria For Applications using OWASP Testing Guide.
- ✓ Web Application Testing – OWASP Web Top 10 2021
- ✓ Mobile Application Testing. – OWASP Mobile Top 10 2024
- ✓ APIs Application Testing. – OWASP API Top 10 2023
- ✓ Windows/Desktop Based Application – OWASP Desktop App Security Top 10 2021
- ✓ AI/ML Based Applicato - OWASP Machine Learning Security Top 10 2023
- Vulnerability Severity will be calculated on CVSS Score 3.0



Approach For Application VAPT/Security Testing/WASA



Approach

Automation Testing, Manual Testing and AI Based Pentesting

1) Automation Testing

- Used of license automation tools to performing testing.
- Automation with predefined test cases helps identifying low hanging fruits

2) Manual Testing

- Bringing human intelligence into testing to perform Business Logic issues.

3) AI Based Security Testing

- AI-Based Security Testing that thinks like an attacker, scans like a machine, and secures like a pro.



Approach

Automation & Manual Testing

Manual Testing

- Bringing human intelligence into testing to perform Business Logic issues.
- Groups of skilled team perform testing Manually on every API-EndPoint /Web Services against OWASP Standards.
- Data Control , Authentication, Authorization and Business Logic flaws which affects application from Security Aspect can only be identify by a Human/Manual Approach.



Glimpse of Security Vulnerabilities Identified in various applications where ABDM APIs were integrated.

#	Vulnerability
01	Patient Health Records can be accessed without any authentication
02	Health Records can be linked with another patient's Unique ID
03	Unauthenticated access to application modules
04	Exposed database connection string leading to full data dump
05	Changes possible during Patient Registration
06	One person can upload a health records to another patient profile
07	Viewing outdated or revoked consent
08	Inappropriate administrative access by standard users
09	Hardcoded API keys in JS files
10	One-Time Password (OTP) verification code bypass





Approach

Automation Testing & Manual Testing

Testing Of Web Application

- Straight Forward, team will browse the Application URL to perform Manual & Automation Testing

Testing Of Mobile Application (Two Types of Approach Involve In Mobile App Testing)

- **1) API Testing** – If the API End Points used in Android/iOS/Web Are exactly same then our team can test API Security Testing from any of the one build (Android/iOS/Web) which have highest number of APIs EndPoints if the APIs are different on (Web/Android/iOS) then team has to test APIs from all 3 builds separately which increase efforts.
- **2) Static Level Security Testing** – Android Operating System & iOS Operating System related vulnerabilities needs to be tested separately on both the Applications, even If the API End Points used in Android/iOS/Web Are exactly same.

Ex. 1. Application Stored User Data On Device, 2.Application Content HardCoded Client_ID or Client_Secret Key, 3. Application Logs Sensitive Data etc.



Approach

Automation + AI Based Testing (60% Weightage)

&

Manual Testing (40% Weightage)



Important Points To Be Noted

1. We can initiate WASA first on NON-ABDM Part while your ABDM APIs are being developed. This way, while your ABDM APIs are being developed or already developed and undergoing successful Functional Testing, we can utilize the time to complete WASA on the Non-ABDM part first. Once the Functional Testing is successfully finished, we can then initiate WASA on the ABDM APIs. This approach will save time. We have been using this strategy for a long time with tremendous results.
2. The WASA Certificate and Report date should be the same day or the day after the Functional Testing is successfully completed and its Report is generated
3. **WASA Should be finished within 60 days of FT completion.**
4. **WASA Activity is one time activity, where we perform one time full application testing and two times retesting of identified security issues.**
5. If the mobile application is developed using a cross-platform framework such as Flutter or Xamarin, or if it utilizes Firebase APIs, the customer must provide all API endpoints and payloads as a Postman collection to us ensure seamless WASA testing.



Important Points To Be Noted

- 1. Application Functionalities/Modules/APIs must run Properly during WASA Testing.**
- 2. To Get Safe to Host Certificate and WASA Closure Report every identified vulnerability needs to be fixed by your Development Team including Critical, High, Medium & Low**
- 3. ABDM APIs must be integrated through a wrapper. If a customer has used ABDM APIs directly in their application, WASA testing cannot start.**
- 4. Post WASA testing, provide ABHA API list and application hashes (File Name, Path, Modified Date) for final deliverables per Cert-In guidelines.**
- 5. It is mandatory for us to submit the Audit Metadata and Full WASA and all types of Audit Activity Reports (First Round and ReTesting Round) within five days of completing any Security Audit/WASA/VAPT to Cert-In. These reports can include closing evidence, such as screenshots of fixed security vulnerabilities and relevant email threads exchanged/MOM with customers/integrators. This documentation allow Cert-In to review and provide any necessary feedback or queries. This is a standard practice we follow for Cert-In documentation**
- 6. Any Application (Web/Mobile/Kiosk) is consuming/communicating with ABHA M1/M2/M3 APIs must be in WASA Scope.**



Important Points To Be Noted

- **If you change or create a new ABDM API Client ID and Client Secret, it's mandatory to conduct Functional and WASA Testing again.**
- **Following Sandbox exit, if you revamp the entire application (whether it's for web, mobile, kiosk, or desktop) with a completely new user interface or revamp the application from scratch, it's mandatory to perform Functional and WASA Testing again.**
- **WASA testing can not be executed If Web/Mobile/Kiosk Application does only have ABDM APIs (M1, M2 & M3) and does not have any other Non ABDM Modules (Patient Registration, Billing, User Management) also your application is not eligible for SandBox exit.**

Please refer this more information - <https://abdm.gov.in/compare4.0> or MVP (Minimum Viable Product (MVP)) Document Published by ABDM



Important Points To Be Noted

We want to highlight several important considerations that should be addressed before commencing the WASA project, based on past customer experiences. Sharing these points in advance will enable your team to proactively address them during the initial WASA discussions:

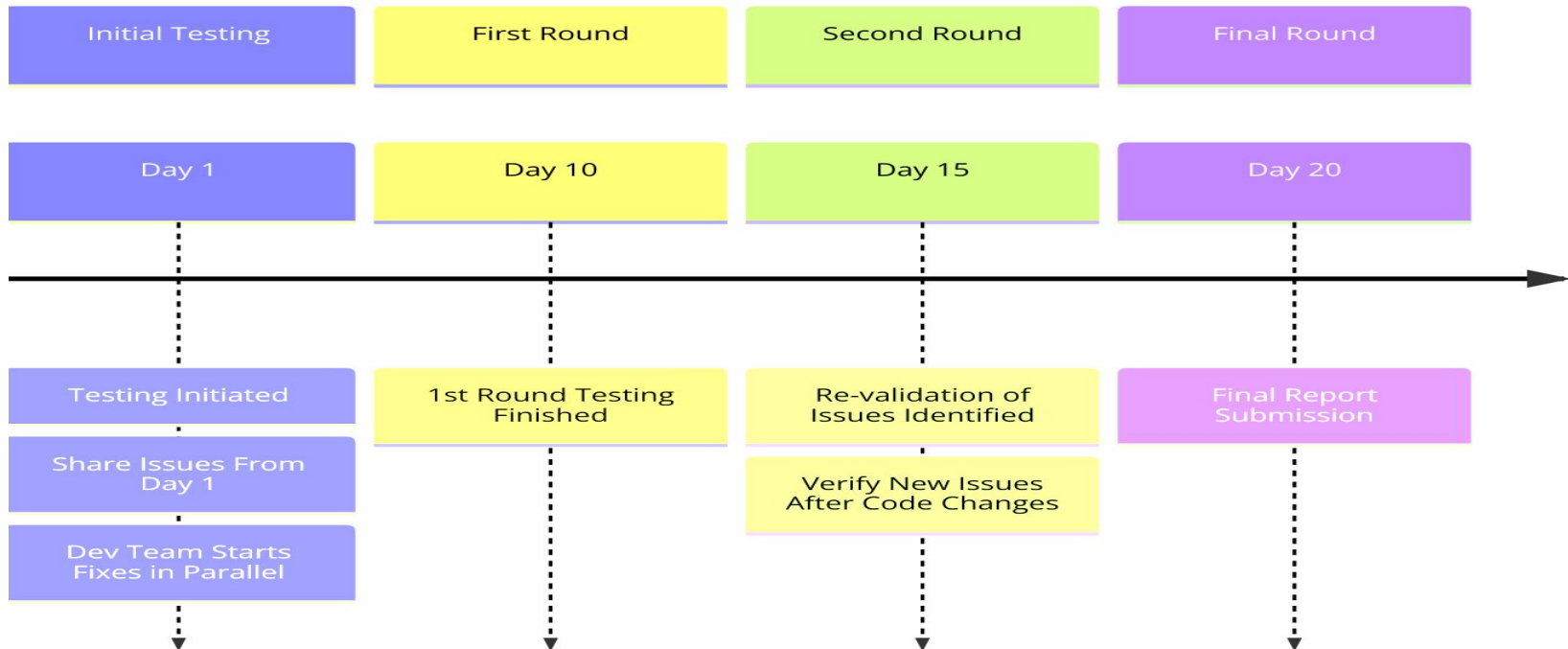
#	Consideration
1. Audit Log Trail	Ensure the application (Web/Mobile/Kiosk/Windows) has an audit log trail with downloadable details: Failed login attempts, usernames, critical actions, login/logout timestamps, IP address, and browser name. OWASP Audit Logging Best Practices
2. Document Expiry or Authentication	PDFs or documents with patient/user data (e.g., prescriptions) should auto-expire within 24–48 hours. Otherwise, require authentication (e.g., OTP) for access.
3. Token Expiry on Logout	Immediately expire authentication tokens/bearer tokens/session IDs on logout or role changes.
4. URL Access Protection	Ensure any data or files accessible via URL (e.g., health records) are protected by authentication.
5. Component Updates	Identify and update outdated components (e.g., jQuery, PHP, Bootstrap, ASP, plugins, SDKs) to the latest stable versions. OWASP Component Security

Reporting



Illustration Scenario For 20 Days Effort (Not Actual Timeline, Just for an example purpose)

Testing and Fixing Process



1. Customers and integrators are required to address the security vulnerabilities identified during our Vulnerability Assessment / Penetration Testing (VAPT). The fixes should be implemented before our team conducts a revalidation, which will take place within 30 days (1 month) from the completion of the first round of testing for the respective web or mobile application.
2. Our team is available Monday to Friday (10 AM – 7 PM) to discuss security concerns and address queries.
3. The WASA team does not provide pre-written code or direct solutions for fixing vulnerabilities. Instead, we share high-level, generic logic that the development/technical team can use to implement the necessary fixes.
4. Once the assessment is completed, the Functional and WASA Report will be sent to NHA, with customer emails in CC.



Final Deliverables From WASA

- 1) WASA Certificate (Safe to Host Certificate) - Non-ABDM and ABDM
- 2) WASA Final Testing Report - - Non-ABDM and ABDM



Escalation Matrix

WASA:

1. Milind Dharmadhikari, Practice Head – Cybersecurity Level 2
milind.dharmadhikari@sumasoft.net
2. Narendra Bhati, Manager (SPOC For WASA) – Level 1
narendra.bhati@sumasoft.net

Functional Testing:

1. Snehal Basale, Head - Quality Assurance Level 2
snehal.basale@sumasoft.net
2. Pritesh Rane, Manager (SPOC For FT) - Level 1
pritesh.rane@sumasoft.net

We Request you to go through ABDM SandBox FAQ

<https://sandbox.abdm.gov.in/sandbox/v3/faq>

Walkthrough of Sample Report/Certificate